

ICS 33.030

CCS M 21

团体标准

T/TAF 209.7—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第7部分：更新升级管理

Evaluation specification for compliance development of mobile Internet
application—Part 7: Update and upgrade management

2024-02-23 发布

2024-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 1

5 APP 更新升级分类..... 2

6 APP 更新升级面临的安全风险..... 2

7 APP 更新升级的个人信息保护要求..... 2

 7.1 APP 传统更新升级的个人信息保护要求..... 2

 7.2 APP 热更新个人信息保护要求..... 2

8 APP 更新升级的安全性要求..... 3

9 APP 更新升级的用户权益保护要求..... 3

 9.1 APP 传统更新升级的用户权益保护要求..... 3

 9.2 APP 热更新的用户权益保护要求..... 3

10 APP 更新升级开发合规评估流程..... 3

11 APP 合规开发更新升级测评方法..... 4

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 209《移动互联网应用程序（APP）合规开发管理测评规范》的第7部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程接口（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、OPPO广东移动通信有限公司、维沃移动通信有限公司、华为技术有限公司、北京快手科技有限公司、荣耀终端有限公司、小米通讯技术有限公司、北京三快科技有限公司、中兴通讯股份有限公司、北京微梦创科网络技术有限公司。

本文件主要起草人：王淞鹤、王艳红、李腾、陈鑫爱、李可心、吴崇武、李实、落红卫、赵晓娜、赵盈洁、姚鹤、王昕、李越、潘洁、王芳、任资政、李辰淑、李沛然、杨明慧、潘万鹏、邹庆、王天。

引 言

T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求，拟由11部分构成。

- 第1部分：总则。目的在于给出规范移动互联网应用程序（APP）合规开发的总体原则和要求。
- 第2部分：需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。
- 第3部分：功能测试。目的在于规范移动互联网应用程序（APP）在合规开发阶段满足功能测试的标准要求。
- 第4部分：代码审计。目的在于规范APP代码审计过程，提升代码安全管理能力。
- 第5部分：对外接口管理。目的在于规范APP对外接口的合规开发和使用管理，提升合规能力。
- 第6部分：应用编程接口（API）管理。目的在于规范APP在开发过程中对于API的使用，提升合规能力。
- 第7部分：更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求，提升APP更新升级管理能力。
- 第8部分：数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理，提升数据使用合规管理能力。
- 第9部分：算法模型。目的在于规范APP合规开发在算法模型方面的要求，提升APP算法模型开发的合规管理能力。
- 第10部分：人员能力。目的在于规范APP在合规开发过程中的人员能力管理。
- 第11部分：能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序(APP)合规开发管理测评规范 第7部分：更新升级管理

1 范围

本文件规定了移动互联网应用程序（APP）合规开发在更新升级阶段的要求。

本文件适用于移动互联网企业在APP开发过程中更新升级前的自评估，也适用于监管部门、第三方评估机构等组织对APP合规开发进行监督、管理和评估，同时也可作为分发平台对APP更新升级包检测的参考。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069—2022 信息安全技术 术语

GB/T 42884—2023 信息安全技术 移动互联网应用程序（APP）生命周期安全管理指南

YD/T 2407—2021 移动智能终端安全能力技术要求

YD/T 4184—2023 移动互联网应用程序（APP）用户权益保护测评规范

3 术语和定义

GB/T 25069—2022界定的以及下列术语和定义适用于本文件。

3.1

热更新 hot update

通过动态下发和加载代码，在APP或SDK不重新下载和安装的情况下，改变其原有代码逻辑或资源文件。

3.2

移动互联网应用程序 mobile Internet application

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的应用程序。

注：包含移动智能终端预置应用、小程序、快应用以及互联网信息服务提供者提供的可以通过网站、应用商店等应用分发平台下载、安装、升级的应用程序，简称APP。

4 缩略语

下列缩略语适用于本文件。

APP: 移动互联网应用程序 (Mobile Internet Application)

5 APP 更新升级分类

按APP更新的方式, 将其分为两大类:

- a) 一种是需要下载并安装APP更新包的传统更新升级, 本文简称为APP传统更新升级。该种方式, 通常在开发管理过程中重新规划新的版本发版, 在分发平台重新审核上架, 用户更新下载版本并安装。
- b) 另一种是热更新, 相较于传统的APP更新, 热更新无需开发者重新发版、分发平台重新审核上架、用户重新下载并安装。

6 APP 更新升级面临的安全风险

APP 更新升级阶段可能会引入新的风险, 包括但不限于:

- a) 恶意绕过上架审核的更新行为或违规热更新行为;
- b) 违规收集个人信息、超范围收集个人信息、违规使用个人信息、强制/频繁/过度索取权限、APP 频繁自启动和关联启动、强制用户使用定向推送功能、欺骗误导用户下载APP、欺骗误导用户提供个人信息等风险;

7 APP 更新升级的个人信息保护要求

7.1 APP 传统更新升级的个人信息保护要求

APP传统更新升级的个人信息保护要求如下:

- a) APP更新升级阶段应遵循原有预置或分发平台的要求。预置应用软件更新升级应满足YD/T 2407—2021中5.5.5.8的a)、b)、c)条要求, 通过分发平台下载安装的APP更新升级时应满足APP上架审核要求。
- b) 当APP版本过低, 存在安全漏洞等问题无法继续正常提供服务时, 应及时推送更新版本, 用户同意后更新升级。
- c) 面向全量用户的APP更新升级, 不应绕过分发平台审核。
- d) APP更新涉及产品功能变化或涉及个人信息处理的目的、方式、范围、变化时, APP开发者应向APP分发平台提供相关材料, 由APP分发平台审核后更新上架。
- e) APP开发者更新升级上架时需要提供的材料包括但不限于: APP更新描述、APP权限使用说明、更新文件、更新范围。
- f) APP开发者应按分发平台要求提前提供相关材料, 并配合APP分发平台更新登记APP上架所需留存主管部门要求的相关信息。

7.2 APP 热更新个人信息保护要求

APP热更新的个人信息保护要求如下:

- a) APP在更新升级阶段, 不应通过热更新方式在APP原有行为基础上增加或变更为侵犯用户权益的行为, 方式包括但不限于更新配置文件、云控开关等。
- b) APP如具备热更新能力, APP热更新在对个人信息处理行为进行变更并会对用户权益产生影响的情况下, 应将热更新的内容、频次及可能造成的影响告知分发平台, 并将热更新包或者文件在

分发平台进行备份，通过分发平台审核。当出现安全修复的紧急情形，可在紧急情况消除后及时告知。

- c) APP热更新至少应通过隐私政策或用户协议等方式告知并征得用户同意，告知内容应该包含：更新目的，涉及的主要功能、是否涉及个人信息处理等。
- d) APP热更新不应改变APP原有的个人信息处理目的、方式和范围，如确需改变个人信息保护处理目的、方式、范围，应具备合法性基础。

8 APP 更新升级的安全性要求

APP更新升级阶段应符合国标GB/T 42884—2023中6.6节更新维护阶段要求。

9 APP 更新升级的用户权益保护要求

9.1 APP 传统更新升级的用户权益保护要求

APP更新升级阶段，应确保其更新升级前后的版本都能满足相关法律法规及YD/T 4184—2023标准的要求。

9.2 APP 热更新的用户权益保护要求

APP热更新升级的用户权益保护要求如下：

- a) 不应通过热更新等方式下发恶意代码或内容损害用户权益。
- b) APP宜提供单独控制热更新功能开启或关闭的选项。

10 APP 更新升级开发合规评估流程

APP更新升级开发合规评估流程如图1所示：

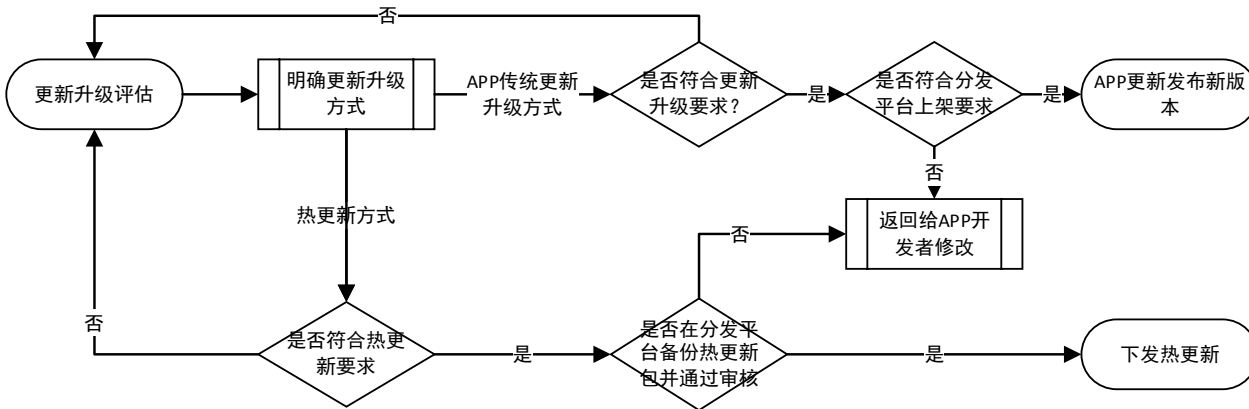


图1 APP更新升级开发合规评估流程图

APP更新升级开发合规评估流程说明如下：

- a) APP更新升级评估；
- b) 明确更新升级方式；
- c) 遵照T/TAF 209进行APP的合规开发及测试；
- d) 评估是否符合更新升级相应方式的要求；
- e) 如果APP是传统更新升级版本，应满足APP传统更新升级要求，并满足分发平台上架审核要求，提交APP版本及相应说明材料，待审核通过后正式发布；
- f) 如果是APP热更新，应满足APP热更新要求，在对个人信息处理行为进行变更并会对用户权益产生影响的情况下，在分发平台备份热更新包及通过审核，待审核通过后下发热更新；
- g) 持续监测APP运行情况，评估是否有新的更新升级需求。

11 APP 合规开发更新升级测评方法

APP更新升级管理的测评方法主要采用资料审查、技术验证和人员访谈对各项要求进行符合性评估。具体见表1。

表1 APP更新升级管理要求与测评方式对应关系表

要求条款	测评方式		
	资料审查	技术验证	人员访谈
7.1 a)	√	√	√
7.1 b)	√	√	√
7.1 c)	√	√	-
7.1 d)	√	√	√
7.1 e)	√	-	√
7.1 f)	√	-	√
7.2 a)	√	√	-
7.2 b)	√	√	√
7.2 c)	√	√	-
7.2 d)	√	√	-
8	√	√	√
9.1	√	√	√
9.2 a)	√	√	-
9.2 b)	√	√	-
注：“√”表示可采用的测评方式；“-”表示不适用。			

电信终端产业协会团体标准

移动互联网应用程序（APP）合规开发管理测评规范
第7部分：更新升级管理

T/TAF 209.7—2024

*

版权所有 侵权必究

电信终端产业协会印发

地址：北京市西城区新街口外大街28号

电话：010-82052809

电子版发行网址：www.taf.org.cn